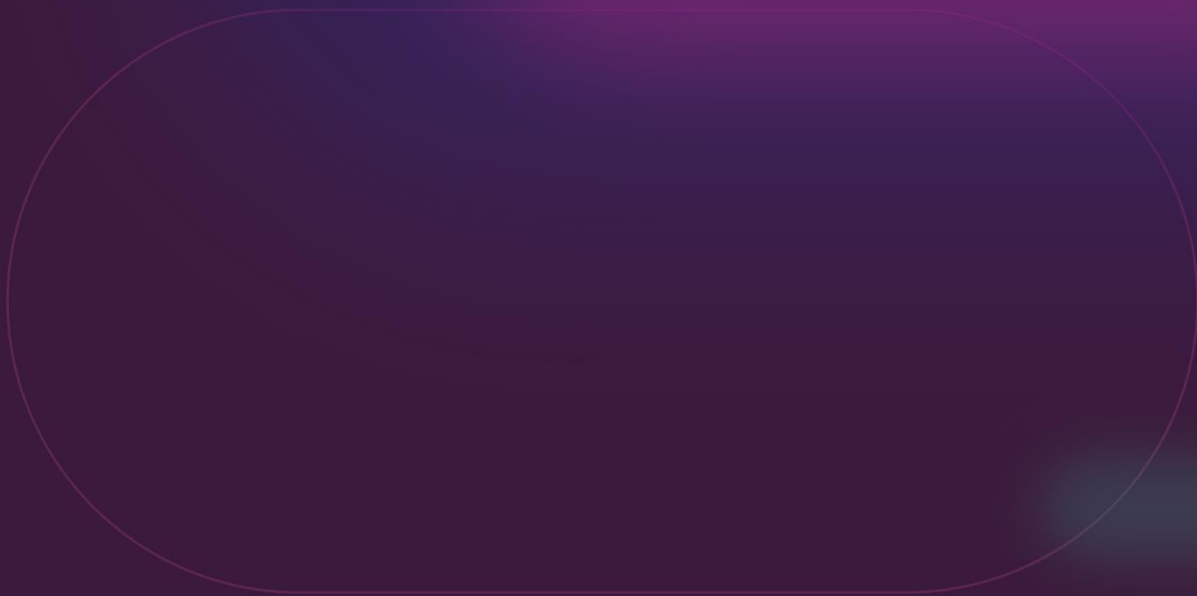


AWS Security & Health Assessment

Information Sheet



Softcat AWS Security Assessment

Introduction

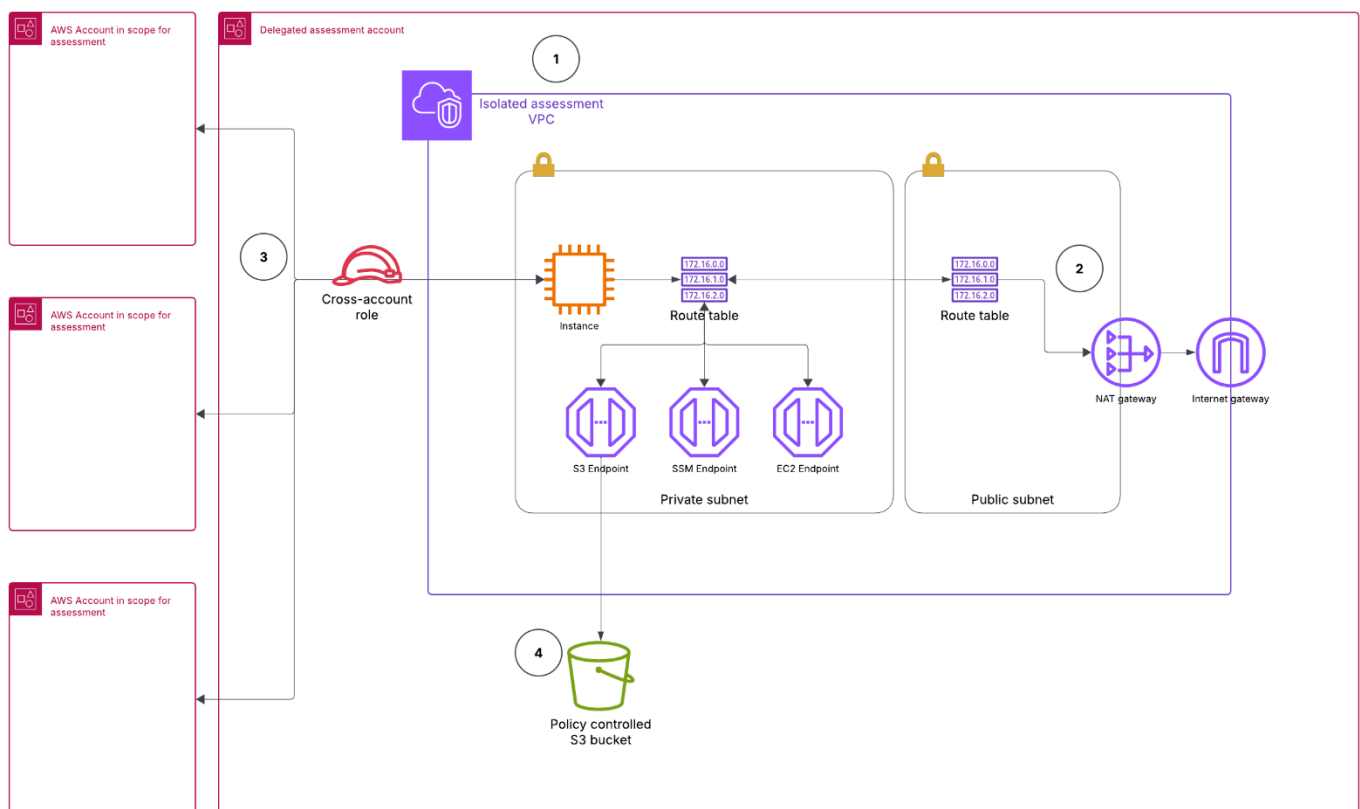
Softcat is a leading provider of IT infrastructure solutions and services with extensive cloud computing and cybersecurity expertise. Our team of certified professionals is dedicated to delivering secure, reliable, and efficient solutions tailored to meet our customers' unique needs. With a strong focus on Client satisfaction and security, Softcat ensures that your AWS environment is protected and optimized for performance.

Overview

At Softcat, we prioritize the security and privacy of our customers' AWS environments. Our security assessment deployment utilises only approved and trusted open-source tooling that does not require Internet access once installed and ensures that your environment remains secure, with no data exposed to the Internet. It contains hundreds of controls covering CIS, NIST 800, NIST CSF, CISA, RBI, FedRAMP, PCI-DSS, GDPR, HIPAA, FFIEC, SOC2, GXP, AWS Well-Architected Framework Security Pillar, AWS Foundational Technical Review (FTR), ENS (Spanish National Security Scheme).

The deployed temporary AWS resources, assessment tooling, and security controls ensure everything is kept local and private.

Deployment Details



Order of operations

The diagram above shows a high-level representation of the temporary tooling deployment to support the SHA. The technical order of operations, as numbered, is as follows:

1. Temporary resources are deployed into the Client's Organization in a delegated assessment account
2. During deployment, the EC2 instance connects to the source repo to download and install the latest version of the assessment tools
3. Assessment tools scan all in-scope accounts in the Organization and record all security findings
4. Findings are collated into several output files, zipped and delivered to the S3 bucket

Once the outputs are delivered to the S3 bucket, the Consultant is notified and will retrieve all files and then empty the bucket and stop the EC2 instance to reduce cost. Further steps beyond what is shown in the diagram are as follows:

5. Consultant filters the findings and processes them into a more manageable format
6. If required, a workshop will be arranged with the Client to gather additional context on findings and ensure recommendations are relevant
7. Consultant adds any recommended remediation detail and next steps to the final report
8. Consultant delivers and presents the final report back to the Client

While the final findings report will be customised to meet the Client's needs, it will likely follow a "traffic light" format, focusing mainly on Critical and high-severity findings and medium-severity if scope and timings allow. Generally, anything below medium-severity will be filtered out of the final report. See below example image:

2.4. SOFTCAT FINDINGS AND RECOMMENDATIONS

The Example Company AWS environment consists of multiple accounts in an organisation. The 14 accounts listed above are in scope for this assessment.

Findings are organised in a Red/Amber/Green format to indicate the level of priority.

Level	Reason	Number of recommendations
Critical	Critical risk items pose a significant threat to the security of the AWS environment and should be addressed as a matter of urgency.	5
High	High-risk items are generally less critical but should still be considered a priority for remediation.	10
De-risked	The current solution is by design or is acceptable when considering the overall picture. It should be de-scoped or noted as an acceptable risk	5

2.4.1. Service: EC2

	Finding	Recommendation	Low impact change
01	EBS snapshots should not be publicly restorable	Identify any public snapshots and set permissions to private.	Yes
02	Security groups should not allow unrestricted access to ports with high-risk	Review each Group and close down ports that are not needed. Consider a redesign or de-risk Where this is impossible without affecting production services.	Yes
03	Security groups should only allow unrestricted incoming traffic for authorized ports	Review each Group and close down ports that are not needed. Consider a redesign or de-risk if this is impossible without breaking something.	Yes
04	The VPC default security group should not allow inbound and outbound traffic	The default security group should be replaced if in use. Check dependencies and configure accordingly.	Yes
05	Port range 0 to 65000 is reachable from an Internet Gateway - TCP	Check the instance and remediate.	No
06	EC2 Transit Gateways should not automatically accept VPC attachment requests	This may be enabled to streamline the automated creation of resources. If it is still useful, it may be pertinent to de-risk. Otherwise, disable auto-accept on each TGW.	Yes

Virtual Private Cloud (VPC)

- We create a temporary VPC in your nominated assessment account, ensuring a secure and isolated network environment for the script to run. These
- The VPC includes a private subnet to host the EC2 instance, which runs the assessment tools, and a public subnet to provide secure outbound internet access via NAT Gateway.
- Internet access is required for the instance to acquire the latest version of the assessment tooling. This approach ensures it is done securely and without affecting your existing resources.

VPC Endpoints

- VPC endpoints for required services are deployed, ensuring secure and private communication within the isolated assessment VPC.
- Endpoint security groups ensure secure access to VPC endpoints from within the VPC.

IAM Roles and Policies

- IAM roles and instance profiles manage permissions securely and ensure these temporary tools cannot overreach or affect resources beyond their required scope.
- Access to accounts in the Organization is provided and secured by deploying Softcat's SHAExec Role to each account, which can then be assumed as needed by the assessment instance. This role and attached policies allow the instance ViewOnly and SecurityAudit permissions, as well as additional custom Get, List and Describe permissions not covered by the managed policies.

EC2 Instance

- An EC2 instance is launched into the temporary isolated VPC's private subnet, which then downloads and installs the necessary tooling.

S3 Bucket

- An S3 bucket is created with strict access controls, allowing only secure HTTPS access from the EC2 instance and explicitly denying all non-HTTPS access.
- The bucket is used to store assessment findings securely.
- Access to the bucket to upload findings is provided via a VPC Gateway Endpoint and secured via Endpoint Security Group, Bucket Policy and IAM Instance Profile.

Notifications and Monitoring

- CloudWatch events and SNS topics notify Softcat when the assessment is complete, and the report is available in the S3 bucket. Once the report is downloaded, the instance is stopped, and copies stored in S3 are deleted to reduce cost.

Security Assurance

- All configurations are designed to keep your environment secure and private.
- No data will be exposed to the internet, and all communications are kept within the VPC.
- The deployment script ensures that all actions are performed securely and in compliance with AWS best practices.

For any questions or further details, don't hesitate to get in touch with your Softcat representative.